요구사항 명세서(SRS) - 금융시스템 보안 연계

1. 문서 정보

- 문서명: 금융시스템 보안 연계 양방향 접근제어 요구사항 명세서(SRS)
- 버전: v0.1
- 작성일: 2026-03-31
- 작성자: [이름]
- 대상: 클라우드-에지 양방향 접근제어(AACE) 기반 금융 데이터 보안 시스템 — 논리 설계 + 시뮬레이션 기반 평가

2. 용어/약어

- AACE: Attribute-based Access Control Encryption (속성 기반 양방향 접근제어 암호화)
- ABAC: Attribute-Based Access Control (속성 기반 접근제어)
- ABE: Attribute-Based Encryption (속성 기반 암호화)
- CP-ABE: Ciphertext-Policy ABE (암호문 정책 기반 ABE)
- ME: Matchmaking Encryption (매치메이킹 암호화)
- Sanitizer: 송수신자 사이에서 정보 흐름을 검증·재암호화하는 에지 서버 역할
- Re-randomization: 암호문을 재암호화하여 보안 우회를 방지하는 기법
- ZTA: Zero Trust Architecture (제로 트러스트 아키텍처)
- DID: Decentralized Identifier (탈중앙화 신원 증명)
- On-chain / Off-chain: 블록체인 원장 기록 / 외부 저장
- No-read rule: 비인가 수신자의 복호화 방지 정책
- No-write rule: 비인가 송신자의 정보 공유 방지 정책

- KYC: Know Your Customer (고객 신원 확인)

3. 목표 및 성공 기준

3.1 목표

- G1: 클라우드-에지 협업 구조에서 송신자와 수신자 양측을 동시에 통제하는 AACE 기반 금융 데이터 보안 모델(절차/데이터/역할)을 설계한다.
- G2: 금융시스템(오픈뱅킹, 마이데이터, 의료보험 등) 환경에 특화된 보안 요구사항(위협 모델 포함)을 명세한다.
- G3: 블록체인과 ABAC의 결합으로 탈중앙화 접근제어 및 감사 가능성을 달성하는 방안을 제시한다.
- G4: 시뮬레이션으로 성능·확장성 관점의 타당성을 평가한다.

3.2 성공 기준

- SC-01: 양방향 접근제어 메시지 흐름(no-read / no-write rule 적용 단계)을 비교표로 제시한다.
- SC-02: 에지 서버(Sanitizer)의 재암호화 처리 절차 및 지연 모델을 시나리오로 제시한다.
- SC-03: 온체인 정책과 오프체인 원문의 무결성 검증 절차를 설계/시뮬레이션으로 제시한다.
- SC-04: 금융 환경 위협 시나리오(내부자 위협, 불법 정보 유출 등)에 대한 방어 단계를 명확히 정의한다.

4. 범위

- **In-scope:** 사용자/기관 속성 기반 접근제어(ABAC/CP-ABE), 양방향 정보 흐름 통제(AACE), 에지 서버 Sanitizer 역할 정의, 블록체인 기반 정책 관리 및 감사 로그, 속성 취소(Revocation) 처리, 금융 데이터 공유 시나리오(오픈뱅킹·마이데이터), 시뮬레이션 평가
- **Out-of-scope:** 실제 금융망(SWIFT 등) 장비 연동, 법적 규제 준수 인증(금융보안원 심사 등), 실측 TPS 측정, 상용 스마트 계약 배포

5. 시스템 개요(논리 아키텍처)

- **구성요소:**

    - Data Owner(금융기관/데이터 송신자) / Data Consumer(수신자/고객·파트너)
    - Edge Server (Sanitizer — 재암호화·정책 검증 수행)
    - Cloud Server (암호화 데이터 저장·전달)
    - Blockchain Network (컨소시엄 권한형 — 접근 정책·속성 취소 기록)
    - Central Authority / CA (속성 인증서 발급)
- **데이터 항목 정의(최소)**
    - D1: 사용자 속성(역할, 소속 기관, 인증 등급, 거래 한도 등)
    - D2: 접근 정책 π (송신자 조건 AS ∧ 수신자 조건 AR)
    - D3: 이벤트 로그 원문(오프체인), 해시/요약(온체인)
    - D4: 암호화 금융 데이터 (재암호화된 암호문)

6. 요구사항 우선순위 규칙

- P0 (Must): 없으면 시스템 성립 불가
- P1 (Should): 성능/완성도에 중요
- P2 (Could): 있으면 좋음(부가)

7. 기능 요구사항(FR)

FR-01: 사용자 속성 등록/갱신

- **우선순위:** P0
- **설명:** 시스템은 금융 사용자(기관·고객)의 속성 정보(역할, 소속, 인증 등급 등)를 등록 및 갱신할 수 있어야 한다.
- **근거(Rationale):** 속성 기반 접근제어의 기반이 되는 신뢰 정보 없이 AACE를 수행할 수 없음.
- **입력:** 사용자 ID, 속성 집합(Attribute Set), 유효기간(optional)
- **처리:**
    - 속성 등록/갱신 이벤트 생성
    - 온체인: 속성 메타데이터 또는 해시 기록
    - 오프체인: 상세 속성 레코드 저장
- **출력:** 등록 성공/실패, 최신 속성 상태 조회 가능

- **예외/오류:** 중복 등록, 만료된 속성 인증서, 정책 위반
- **검증:** 등록 후 조회 시 동일한 속성 정보가 반환되는지 확인; 온체인 해시와 오프체인 원문 일치 확인

FR-02: 양방향 접근 정책(π) 정의 및 집행

- **우선순위:** P0
- **설명:** 시스템은 송신자 조건(AS)과 수신자 조건(AR)을 동시에 명시한 접근 정책 π를 정의하고, 이를 데이터 공유 시마다 집행할 수 있어야 한다.
- **근거:** No-read rule + No-write rule의 동시 적용이 AACE의 핵심이며, 금융 내부자 위협 방지에 필수.
- **입력:** 정책 π = (AS, AR), 데이터 객체 식별자
- **처리:**
  - 송신자 속성이 AS를 만족하는지 검증
  - 수신자 속성이 AR를 만족하는지 검증
  - 양측 조건 불만족 시 통신 차단
- **출력:** 정책 검증 결과(허용/차단), 차단 시 사유 코드
- **예외:** 정책 파일 불일치, 속성 만료, 미등록 속성
- **검증:** 허가/비허가 시나리오에서 각각 통신 허용 및 차단이 올바르게 동작하는지 확인

FR-03: 에지 서버(Sanitizer) 재암호화 및 정보 흐름 통제

- **우선순위:** P0
- **설명:** 시스템은 에지 서버가 모든 데이터 전송 경로에 위치하여, 메시지 신선도 확인·서명 인증·재암호화(Re-randomization)를 수행하도록 해야 한다.
- **근거:** 악의적인 송신자가 평문으로 우회 전송하는 것을 원천 차단하기 위함.
- **입력:** 암호화된 데이터, 송신자 서명, 정책 π
- **처리:**
  1. 메시지 신선도(Freshness) 확인 → 오래된 메시지 즉시 거부
  2. 송신자 디지털 서명 인증
  3. 정책 π에 따른 속성 대조 (AS 검증)
  4. 검증 성공 시 암호문 재암호화(Re-randomization)

5. 재암호화된 암호문을 수신자 또는 클라우드로 전달

- **출력:** 재암호화된 암호문 또는 차단 응답
- **예외:** 서명 불일치, 신선도 검사 실패, 정책 위반
- **검증:** 에지 서버를 통하지 않은 평문 전달 시도가 수신자에게 도달하지 않는지 확인

FR-04: 속성 취소(Revocation) 즉시 반영

- **우선순위:** P0
- **설명:** 시스템은 사용자 속성 취소/만료 시 이를 즉시 반영하여 이후 데이터 접근을 거부해야 한다.
- **입력:** 사용자 ID, 취소된 속성
- **처리:** 블록체인 원장에서 최신 속성 상태 확인; 취소 속성에 해당하는 암호키 무효화
- **출력:** 접근 거부 및 사유 코드
- **검증:** 속성 취소 후 접근 시도 시 반드시 실패 처리되는지 확인

FR-05: 블록체인 기반 접근 정책 관리

- **우선순위:** P0
- **설명:** 시스템은 접근 정책(π)을 블록체인에 기록하고, 스마트 계약을 통해 정책 추가/변경/조회를 수행할 수 있어야 한다.
- **입력:** 정책 π, 정책 등록/변경 요청자 속성
- **처리:** 스마트 계약 실행 → 정책 온체인 기록; 오프체인 정책 상세 연동
- **출력:** 정책 등록/변경 결과, 최신 정책 조회 가능
- **검증:** 정책 변경 후 이전 정책으로의 접근이 차단되는지 확인

FR-06: 이벤트 로그 무결성 기록(온·오프체인)

- **우선순위:** P0
- **설명:** 시스템은 접근제어 이벤트 로그에 대해 무결성 검증 가능한 기록 방식을 제공해야 한다.
- **입력:** 이벤트 원문(시각, 송수신자 속성 요약, 정책 ID, 결과)
- **처리:** 오프체인 원문 저장; 온체인 해시/요약 기록
- **출력:** 로그 조회 + 무결성 검증 결과(일치/불일치)

- **검증:** 오프체인 원문 변조 시 온체인 해시 검증이 실패하는지 확인

FR-07: 금융 데이터 공유 시나리오 — 오픈뱅킹/마이데이터

- **우선순위:** P1
- **설명:** 시스템은 오픈뱅킹 및 마이데이터 서비스 환경에서 고객(데이터 주체)이 특정 금융기관(수신자)에게만 데이터를 공유하도록 속성 기반 조건을 명세해야 한다.
- **입력:** 고객 속성, 금융기관 속성(인가 기관 여부, 서비스 범위 등), 공유 목적
- **처리:** 정책 π = (고객 동의 속성 AS, 인가 기관 속성 AR) 집행
- **출력:** 조건 만족 시 암호화된 금융 데이터 전달; 불만족 시 차단
- **검증:** 비인가 금융기관의 접근 시도가 차단되는지 확인

FR-08: 프라이버시 보호 — 속성 익명화 및 정책 숨김

- **우선순위:** P1
- **설명:** 시스템은 접근 정책 및 사용자 속성이 제3자에게 노출되지 않도록 정책 숨김(Policy Hiding) 및 속성 익명화 메커니즘을 포함해야 한다.
- **입력:** 사용자 속성 집합, 정책 π
- **처리:** 속성 정보 암호화; 동형 암호 기반 속성 검증(식별 없이 권한 확인)
- **출력:** 프라이버시 보호 상태에서의 정책 집행 결과
- **검증:** 정책 집행 과정에서 실제 속성값이 에지 서버 또는 클라우드에 노출되지 않는지 설계 논리로 확인

8. 비기능 요구사항(NFR)

NFR-01: 성능(지연) 분석 가능성

- **우선순위:** P0
- **설명:** 시뮬레이션에서 데이터 공유 지연을 구성요소별(속성 검증/재암호화/블록체인 조회/로그 기록)로 분해하여 분석할 수 있어야 한다.
- **검증:** 지연 모델의 변수/가정/측정 항목이 문서에 명시되어 있는지

NFR-02: 확장성(이벤트 증가) 분석 가능성

- **우선순위:** P0

- **설명:** 사용자 수/트랜잭션 증가에 따른 병목 지점을 식별하고, 에지 분산 처리 및 온·오프체인 분리를 통한 완화 설계를 제시해야 한다.
- **검증:** 부하 시나리오(사용자 수, 요청율)를 최소 2개 이상 정의했는지

NFR-03: 보안 요구사항 충족(논리)

- **우선순위:** P0
- **설명:** 리플레이 공격/스푸핑/중간자(MITM)/내부자 위협에 대한 방어 요소가 양방향 접근제어 절차에 포함되어야 한다.
- **검증:** 공격별 '차단 단계/근거'가 명시되어 있는지

NFR-04: 감사 가능성

- **우선순위:** P1
- **설명:** 금융 사고 발생 시 로그 기반 추적이 가능하도록 이벤트 필드(최소 항목) 및 조회 절차를 정의해야 한다.
- **검증:** 감사 시나리오('언제/누가/어떤 속성으로/어떤 결과') 재구성이 가능한지

NFR-05: 프라이버시

- **우선순위:** P1
- **설명:** 설계는 금융 고객의 개인 속성 노출 가능성을 줄이기 위한 원칙(속성 익명화, 정책 숨김, 최소 권한)을 포함해야 한다.
- **검증:** 속성 프라이버시 보호 정책 및 범위가 문서화되어 있는지

NFR-06: 규제 연계 고려

- **우선순위:** P2
- **설명:** 설계는 금융 관련 규제(개인정보보호법, 전자금융거래법, 마이데이터 법령)와의 연계 가능성을 고려하여, 감사 로그 보존 기간 및 접근 제어 정책 명세 형식을 정의해야 한다.
- **검증:** 규제 항목과 SRS 요구사항 간 매핑 테이블이 존재하는지

9. 가정/제약

- A1: 블록체인은 권한형(컨소시엄) 환경을 가정한다.
- A2: 실제 금융망 연동 없이, 속성 기반 접근제어 흐름 및 지연 모델 기반 시뮬레이션으로 평가한다.

- A3: 에지 서버(Sanitizer)는 신뢰할 수 있는 제3자(TTP)가 아닌, 정책 집행 노드로 가정하며 데이터 내용을 복호화할 수 없다.
- A4: 합의 알고리즘 및 네트워크 지연은 시뮬레이션 파라미터로 모델링한다. (예: 지연 범위, 노드 수, 이벤트율)
- A5: 금융 데이터의 분류(민감도 등급)는 속성 집합으로 추상화하여 표현한다.

10. 검증(테스트/평가) 계획

- EV-01: 양방향 정책 집행 비교 (단방향 ACE vs AACE — 내부자 위협 시나리오)
- EV-02: 에지 서버 재암호화 지연 분석 (속성 검증/재암호화/전달 분해)
- EV-03: 확장성 시나리오 (사용자 수/트랜잭션 증가에 따른 병목 분석)
- EV-04: 위협 시나리오 논리 검증 (리플레이/스푸핑/내부자 불법 유출)
- EV-05: 블록체인 로그 무결성 검증 (오프체인 원문 ↔ 온체인 해시)
- EV-06: 속성 취소 후 접근 차단 동작 확인
- EV-07: 정책 숨김 적용 시 프라이버시 보호 논리 검증

부록 A. 자료조사 요약(요구사항 근거)

- **FR-02 근거:** AACE 모델은 no-read rule과 no-write rule을 동시에 적용하여 기존 단방향 ACE의 한계(악의적 송신자 통제 불가)를 극복함.
- **FR-03 근거:** 에지 서버를 Sanitizer로 활용하면 클라우드 부담을 줄이면서 실시간 재암호화 및 정책 집행이 가능함.
- **FR-05 근거:** 블록체인의 불변성/감사추적 특성이 금융 접근 정책의 위변조 방지와 신뢰성 있는 감사 로그 확보에 기여함.
- **NFR-02 근거:** 확장성 문제(블록체인 부풀림, 합의 지연)를 온·오프체인 분리 및 에지 분산 처리로 완화하는 접근 (EPREAR, AACE 논문 참조).
- **NFR-06 근거:** 오픈뱅킹·마이데이터 환경에서 ABAC 기반 세밀한 접근제어는 금융 규제 준수와 자연스럽게 연계됨 (캡스톤 논문-2 소스 참조).